



Access Control Policy

TechAhead

This document contains proprietary information of TechAhead. No part of this publication may be reproduced, stored in a retrieval system or transmitted in any form or by any means, whether electronic, mechanical, photocopying, recording or otherwise, without the prior written permission of TechAhead. The information contained herein is confidential to other than TechAhead and shall not be distributed to any persons other than those involved in the assessment and delivery of services. TechAhead reserves the right to revise and update this document as and when required. TechAhead reserves the right to withdraw the document excluding customer specific information at the time of termination of services.

Table of Contents

1. PURPOSE 3

2. SCOPE 3

3. LOGICAL ACCESS CONTROLS..... 3

4. PHYSICAL ACCESS CONTROLS..... 4

5. REVIEW OF USER ACCESS RIGHTS..... 6

6. MANAGEMENT PREROGATIVE: 6

1. Purpose

The purpose of the Access Control Policy is to ensure that appropriate level of protection is applied to protect the information of TechAhead.

2. Scope

This policy applies to all the information processing facilities and premises of the TechAhead.

3. Logical Access Controls

3.1 Policy Statement

The access to information and Information Systems (Operating Systems, Applications, Databases, network equipments and others) shall be according to the principles of "least privilege" and "need to know" basis. The procedures shall be administered to ensure that the appropriate level of access control is applied to protect the information in each application or system from unauthorized access, modification, disclosure, or destruction to ensure that information remains accurate, confidential, and is available when required.

3.2 User Access to Information and Software

- Access must be provided according to the user's requirement to read / execute / write / modify / delete information based on the principle of least privilege to achieve the desired job function.
- Users must be defined only once on each Information system / Application.
- Duplicate user-ids must not be created on Information Systems. A check for duplicate IDs must be carried out at least once a year.
- User IDs (Domain ID, Mail ID etc.) for external agency representatives must not be created until authorized by Department Head.
- E-mail IDs for external agency representatives must not be routable outside unless business need is established.

3.3 User Account Management Rules for Domain Controller, email / messaging servers

- Every administrative / privileged account must have one-to-one relationship with an individual. Access to any resource of Information System via shared administrative / special privileges user accounts is not permitted unless authorized by the Technology department.
- Generic / Test User IDs are not created unless authorized by the Technical department.
- All generic user IDs, test IDs created must have an owner who shall be accountable for the use of such IDs and revocation for the same.
- The logs of such user IDs are monitored. The continuation of the use of these IDs must be reviewed by the Technology Department every three months.
- User accounts with administrative / special privileges on Information Systems are provided only to a limited number of authorized personnel who have been identified by the Technology department.
- "Guest" account or feature must be disabled on all servers.

3.4 Password Management

All logical access shall be controlled through secure Password. Password controls in terms of generation, usage and modification shall be as per "User Password Management Process"

3.5 Review of User Access Rights

Privileged user's access rights (administrative & special privilege) for critical Information systems must be reviewed at least every 3 months.

3.6 Unattended User Equipment (Servers)

Session timeout of 15 minutes must be set for inactive telnet and SSH sessions for routers and switches, telnet, TTY and SSH sessions to Linux servers and terminal client connections to Windows servers.

Password protected screensavers with an inactivity timeout of 5 minutes must be enabled on all servers.

3.7 User Responsibility and Access Controls

No user shall use another user's account to gain access to Information Systems.

Users must enable a screensaver on workstations within a timeframe of 5 minutes of inactivity.

In order to protect sensitive documents, being sent as attachments, Users must password-protect the same.

3.8 Unattended User Equipment (Workstations)

All users must terminate their active sessions or lock their workstations while leaving them unattended.

3.9 PC / Laptop Logical Security

The operating systems of PCs / laptops must be updated with the latest vendor recommended security patches or as recommended by the Technology Manager at least on weekly basis, preferably through an automated mechanism.

The Technology Department must carry out audit of workstations (on a sample basis) at least every six months to check for patch updates status.

Employees / trainees / contract personnel must not carry and use personal laptops within work areas without permission of TechAhead authority.

All workstations / laptops must have anti-virus software installed. The available virus definitions patches must be updated at least weekly through an automated mechanism or manually in case automated mechanism fails.

3.10 Usage of Sensitive System Utilities

Access to administration utilities and system configuration utilities must be available only to authorized personnel.

4. Physical Access Controls

4.1 Policy Statement

Physical access to TechAhead premises shall be controlled to prevent, detect, and minimize the effects of unauthorized access to these areas. The policy shall be administered to ensure appropriate physical protection requirements, which safeguard the IT infrastructure. Appropriate prevention and detection controls against environmental hazards shall also be implemented.

4.2 Identification and Proximity Cards

- Access to data processing units is controlled and restricted to authorized personnel through Proximity Card based Access Control System
- All Employees, trainees, contract personnel and visitors must be required to wear some form of visible identification i.e., employee access card / visitor-badges.
- Security Personnel must question unescorted strangers not wearing visible identification.
- Security personnel at all exits must ensure that visitor's badge is collected when the visitor leaves the premises.
- Reconciliation of badges issued to visitors must be done at the end of each day.

- Issue of proximity cards to employees, trainees and contract personnel must be done in a controlled manner.
- The record of issuance of ID and proximity cards must be maintained.
- All proximity cards must be issued with validity till employment in company/training period/contract period after which these must be automatically disabled.
- Every employee, trainee, and contract personnel, who has been issued a proximity card must immediately report loss or theft of card to the Human Resource & Administration Department.
- The Human Resource & Administration Department must immediately deactivate proximity cards of employees / trainee / contract personnel when loss of card is reported and reissue the same against stipulated penalty.
- The original Proximity card must be taken back by Human Resource Administration Department, wherever possible (e.g., broken, damaged cards) while issuing a new card to an employee.
- The HRA department through its clearance process must ensure that timely notification is sent to the administration department regarding the resignation / termination of employees.
- The HRA department must ensure that access cards of employees leaving the organization is collected and promptly disabled.
- The non-returned proximity cards must be blocked by the HRA Department.
- A list of non-returned proximity cards must be compiled and maintained by the HRA Department.
- Proximity Card Issue Register and the entries of Issued Cards in the Access Control Software must be reconciled at least once in 6 months.
- Inventory of un-issued proximity cards must be maintained and the same must be verified against the physical stock at least once in 6 months.

4.3 Electronic Access Control System

- The system on which the access control software is installed must be adequately secured.
- The access must be reviewed every 6 months.
- The Access Control System Operator must not have Administrator rights on the operating system.
- The access control devices installed inside the premises must have option for emergency deactivation.
- All doors equipped with electronic access controls must be closed immediately and should be locked automatically.
- Electronic magnetic door locks must not be deactivated without prior permission from the HRA Department unless needed for emergency evacuation in case of events like fire / earthquake.
- Access Violation Reports from the Access Control Software for sensitive areas such as datacenters, network rooms, electrical / UPS rooms must be securely maintained and reviewed by the respective Administration Department on fortnightly basis.
- Access rights to Data Processing Units must be reviewed at least once in 6 months.

4.4 Third Party Access Control

- Vendors, consultants, and contractors must be subjected to the least access privilege necessary to achieve the desired function. Further, the third-party users must be restricted to the minimum information required to complete the contracted work.
- All third-party users accessing information belonging TechAhead must be provided with a unique login-id and password, to maintain accountability.

5. Review of User Access Rights

Management should review the user's access rights at regular intervals using a formal process.

This may include:

- Conducting internal Audit
- Reallocation of user rights by administrator and documenting the same when employee is transferred internally.
- Checking the access of shared folder frequently

6. Management Prerogative:

The Management reserves the right to amend, change or modify this policy at any time.